Business Requirements Document (BRD): The-SIFT

Multi-Tenant IoT Smart-Home Automation Platform

Prepared by:

- **Shreyash Vaigankar** (Seat No: `25P0320045`)
- **Samuel D'Souza** (Seat No: `25P0320041`)

---

1 Executive summary

The-SIFT (Scalable IoT For Tenants) is a cloud-native, multi-tenant IoT smart-home automation platform deployed on a 2-node **Kubernetes (K3s)** cluster on **AWS EC2**. Traditional smart-home systems are built for a single household on a local network. **The-SIFT** overcomes this limitation by automatically provisioning an isolated cloud smart-home environment for each registered household (tenant), authenticating their IoT devices over **MQTT**, and providing centralized fleet observability for administrators.

1.1 End-to-End System Flow

1. **Account & Tenant Onboarding:** A user registers an account and creates a household tenant through the custom **Provisioning API** (Node.js and **SQLite**), selecting either a `single` plan (1 member, up to 10 devices) or a `family` plan (up to 6 members, up to 30 devices).
2. **Automated Kubernetes Provisioning:** The Provisioning API automatically creates a dedicated Kubernetes namespace (`tenant-<slug>`) enforced with strict isolation policies and deploys a private **Home Assistant** instance exposed via **Traefik Ingress**.
3. **Secure IoT Messaging:** The API creates a dedicated workspace in **Magistrala v1.0.0** (**Atom IAM**, **FluxMQ** MQTT broker, and **PostgreSQL**) with separate MQTT telemetry and command channels. Household members share and control their registered **ESP32** or simulated devices through Home Assistant.
4. **Centralized Observability:** A custom **telemetry bridge** service subscribes to Magistrala telemetry channels and forwards live device data to **ThingsBoard CE**, allowing platform administrators to monitor all tenants from a central dashboard.

---

2 Project objectives

- **O1 — Multi-Tenant Isolation:** Enforce strict tenant isolation using Kubernetes namespaces, `NetworkPolicy`, `ResourceQuota`, `LimitRange`, restricted `ServiceAccount`, and `Pod Security Standards`.
- **O2 — Automated Onboarding:** Automate tenant namespace creation, user management, and device registration through the **Provisioning API**.
- **O3 — Secure IoT Connectivity:** Authenticate IoT devices and isolate MQTT traffic using **Magistrala v1.0.0** (**Atom IAM** and **FluxMQ**).
- **O4 — Multi-User Households:** Support multi-user households with user accounts, subscription plans (`single` and `family`), role-based access control (`owner`, `admin`, `member`),

and shared household devices.

- **O5 — Centralized Monitoring:** Provide platform-wide telemetry visualization across all tenants using **ThingsBoard CE**.
- **O6 — Scalability and Resilience Verification:** Verify isolation, pod self-healing, node-failure behavior, and performance through automated tests and load testing (tested with up to 10 concurrent devices, with an architecture designed to scale to 100–1,000 devices).
- **O7 — Cost-Optimized Cloud Architecture:** Deploy the platform on **AWS EC2** using **K3s** and in-cluster services to minimize monthly cloud costs compared to a fully managed AWS baseline.

---

3 Project scope

3.1 In Scope

- **2-Node K3s Cluster on AWS EC2:**
  - **Node 1 (Identity & Control Node):** Runs the K3s control plane, **Traefik Ingress**, and **Magistrala v1.0.0** (**Atom IAM**, **FluxMQ**, and **PostgreSQL**).
  - **Node 2 (Worker Node):** Runs **ThingsBoard CE**, isolated per-tenant **Home Assistant** pods, the **Provisioning API**, and the **telemetry bridge**.
- **Provisioning API & Account Management:** Node.js and **SQLite** service for email/password authentication, tenant creation, `single` and `family` plan enforcement, direct member management (`owner`, `admin`, `member`), and device registration.
- **Per-Tenant Isolation & Smart Home:** Automated **Helm**-based deployment of an isolated **Home Assistant** instance per tenant inside `tenant-<slug>`, locked down with a default-deny `NetworkPolicy`, `ResourceQuota`, `LimitRange`, restricted `ServiceAccount`, `PriorityClass`, and `Pod Security` labels.
- **IoT Messaging & Telemetry Pipeline: Magistrala v1.0.0** workspace per tenant with separate telemetry and command MQTT channels, plus the Node.js **telemetry bridge** forwarding data to **ThingsBoard CE**.
- **Device Lifecycle & Simulation:** API endpoints to register devices, rotate secrets, and revoke credentials, supported by a virtual IoT device simulator (tested up to 10 devices) and **ESP32** firmware support.
- **Verification & Load Testing:** Automated security and isolation checks, node-failure recovery tests, and load tests measuring throughput, latency percentiles, CPU/memory usage, and provisioning time.

---

4 Business requirements

4.1 Functional Requirements

ID	Requirement Description	Verification Method
FR-01	The **Provisioning API** accepts an authenticated tenant-creation request (slug, display name, plan) and returns the tenant URL and shared **Home Assistant** credentials.	Create a tenant via the API and verify access to the provisioned Home Assistant URL.
FR-02	The system automatically creates a **Magistrala** workspace, a telemetry channel, a command channel, and MQTT credentials for each tenant.	Inspect the created workspace, channels, and credentials in Magistrala after onboarding.
FR-03	The system automatically deploys an isolated **Home Assistant** instance in a dedicated namespace (`tenant-<slug>`) with a default-deny `NetworkPolicy`, `ResourceQuota`, `LimitRange`, restricted `ServiceAccount`, and `Pod Security` label.	Run automated Kubernetes namespace, `NetworkPolicy`, and `ResourceQuota` checks.
FR-04	Device telemetry routes through **Magistrala** MQTT to the tenant's **Home Assistant** pod and, via the **telemetry bridge**, to **ThingsBoard CE**.	Publish device telemetry and confirm live delivery in both Home Assistant and ThingsBoard CE.
FR-05	Tenant owners and admins can register simulated or **ESP32** devices via the API, view credentials once on creation, rotate secrets, and revoke devices.	Test device registration, secret rotation, and revocation through the API.
FR-06	No tenant can access another tenant's data, devices, or Kubernetes network resources.	Execute cross-tenant network, API authorization, and MQTT channel isolation tests.
FR-07	Platform administrators can view centralized, platform-wide device telemetry across all tenants in **ThingsBoard CE**.	Verify live multi-tenant telemetry dashboards in ThingsBoard CE.
FR-08	Invalid or revoked device credentials are rejected by **Magistrala**, and no messages from unauthorized devices are delivered.	Attempt MQTT connections and publishing with invalid and revoked credentials.
FR-09	Crashed pods restart automatically; upon worker node failure, stateless tenant pods reschedule to the surviving node if capacity exists, while node-bound stateful services (**ThingsBoard CE**, databases) do not fail over.	Execute pod-crash and worker node failure experiments.
FR-10	Load testing with simulated devices records message delivery rate, latency percentiles, CPU/memory usage, and tenant provisioning time (tested up to 10 devices, designed to scale to 100–1,000 devices).	Run simulated device load scenarios up to 10 devices and record performance metrics.
FR-11	Users can register an account and log in via the API using email and password (stored as salted hashes), kept separate from device MQTT credentials.	Test account registration, password hashing, and API login authentication.
FR-12	The API enforces `single` plan (1 seat, 10 devices) and `family` plan (6 seats, 30 devices) limits; owners can change plans, and downgrades are blocked if active seats or devices exceed the new limits.	Test seat/device limit enforcement and plan downgrade rules via the API.

continued on next page

ID	Requirement Description	Verification Method
FR-13	Every member has an enforced role (`owner`, `admin`, `member`) checked on every API request; each tenant has one owner who cannot be removed or demoted unless ownership is transferred.	Test role-based access control on API endpoints and owner protection rules.
FR-14	Devices belong to the tenant so all active household members can view the same telemetry and control the same devices.	Verify that two members of a family tenant can view and control the same device.
FR-15	Commands sent from a tenant's **Home Assistant** instance are published on that tenant's command channel and reach only that tenant's devices.	Send device commands from Home Assistant and verify cross-tenant command isolation.

4.2 Non-Functional Requirements

- **Multi-Layer Isolation:** Enforced across Kubernetes namespaces, `NetworkPolicy`, `ResourceQuota`, and **Magistrala** MQTT channels/credentials.
- **Credential Security & Rate Limiting:** Platform logins, Magistrala device secrets, and Home Assistant credentials are separated; sensitive values use `Kubernetes Secrets`, and login routes are rate-limited.
- **Cluster Capacity:** Supports up to 3 simultaneously active tenants within node RAM limits (~512 MB RAM per Home Assistant pod) and is tested with up to 10 simulated devices (designed to scale to 100–1,000 devices).
- **Self-Healing Containers:** All services run in containers on **K3s** with Kubernetes `livenessProbe` and `readinessProbe` health checks for automatic restart.

---

5 Key stakeholders

Stakeholder Role	Responsibilities
Project Members — Shreyash Vaigankar (`25P0320045`) & Samuel D'Souza (`25P0320041`)	Design the cloud architecture, implement platform services and Kubernetes manifests, run verification and load tests, and prepare documentation.
Tenant Owner / Admin	Creates a household tenant, manages subscription plans (`single` or `family`), adds or removes members, and registers IoT devices via the **Provisioning API**.
End User / Household Member	Accesses the household's isolated **Home Assistant** dashboard and operates shared smart-home devices.
Platform Administrator	Monitors fleet-wide telemetry and device health across all tenants using **ThingsBoard CE**.

---

6 Project constraints

- **Per-Tenant Memory Limit:** Each isolated **Home Assistant** pod requires ~512 MB of RAM alongside **ThingsBoard CE** and **Magistrala**, limiting the 2-node cluster to 3 simultaneously active tenants during evaluation.
- **Single Control Plane (Non-HA):** The K3s server node acts as a single control plane, and stateful services (**PostgreSQL**, **SQLite**, **ThingsBoard CE**) are bound to their assigned nodes without automatic cross-node failover.
- **Shared Home Assistant Login:** Because **Home Assistant** lacks native per-device user permissions and a version-stable user management API, household members share one tenant login for Home Assistant.
- **ThingsBoard CE Broker Integration: ThingsBoard Community Edition** lacks native external MQTT broker integrations, requiring the custom **telemetry bridge** service to forward data from **Magistrala**.
- **Separate MQTT Channels:** Inbound telemetry and outbound commands use two separate **Magistrala** channels per tenant to enforce directional traffic isolation.

---

7 Cost-benefit analysis

Using AWS `us-east-1` On-Demand pricing (730 hours/month), **The-SIFT** reduces monthly cloud infrastructure cost from ~**$293.31/month** (standard managed AWS baseline) to ~**$174.95/month**:

Baseline Managed AWS Component (10 Tenants Reference)	**Baseline Monthly Cost**	**Optimized Architecture in The-SIFT**	**Optimized Monthly Cost**
EKS Control Plane	$73.00	**Self-managed K3s Control Plane** (runs on Identity EC2 node)	$0.00
2 × `t3.large` Worker Nodes	$121.47	**2 × EC2 `t3.large` Nodes** (Node 1: Identity & Magistrala; Node 2: ThingsBoard CE, Home Assistant pods & APIs)	$121.48
RDS PostgreSQL, 2 × `db.t3.micro` with 20 GB each (single-AZ)	$29.42	**In-cluster PostgreSQL & SQLite** with dedicated EBS `gp3` telemetry storage for ThingsBoard CE & Magistrala (200 GB)	$16.00
Application Load Balancer (light traffic) + **NAT Gateway**	$55.27	**Traefik Ingress + K3s ServiceLB** with outbound MQTT/HTTP telemetry transfer & snapshot backups	$26.97
Public IPv4 Addresses (3)	$10.95	**2 × Public IPv4 Addresses** (1 per EC2 node)	$7.30
Worker Node Root Volumes, 2 × 20 GB	$3.20	**2 × 20 GB EBS `gp3` Root Volumes**	$3.20
Total Baseline Cost	**~$293.31 / month**	**Total Optimized Cost for The-SIFT**	**~$174.95 / month**